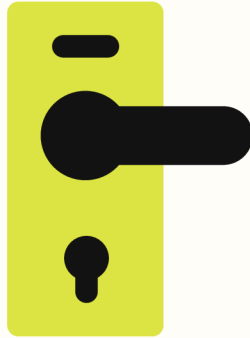


REPORT



TEST WEB APPLICATION

Vulnerability Assessment Report

Target: Demo Web Application

Prepared by: SARAVANAN
Date: May 2026

SUMMARY

This report summarizes the security assessment performed on a web application.

Several issues were identified, including missing security headers and input validation weaknesses.

These vulnerabilities may expose the application to attacks such as cross-site scripting.

Appropriate fixes are recommended to improve security posture.

Scope

Target: http:
//portswigger.net

Testing Type:
Passive scanning and manual testing

Out of Scope:

- Denial of Service testing
- Brute-force attacks

Tools Used

- Nmap (Network scanning)
- OWASP ZAP
- Browser DevTools (Manual testing)
- Burp Suite (Request interception – optional)

Finding

Vulnerability: Missing Security Headers

Risk: Medium

Description:

The application does not include security headers such as Content-Security-Policy.

Impact:

Attackers may exploit this to perform XSS attacks.

Recommendation:

Configure server to include proper security headers.

Evidence

The screenshot displays the Burp Suite application window. The title bar reads "Untitled Session - 20260505-1". The menu bar includes File, Edit, View, Analyse, Report, Tools, Import, Export, Online, and Help. The toolbar contains icons for standard mode, file operations, and analysis tools. The left sidebar shows a tree view with "Sites" (containing a plus icon), "Contexts" (containing "Default Context"), and "Sites". The main panel is titled "Quick Start" and contains the following text:

This screen allows you to launch an automated scan against an application - just enter its URL below and press 'Attack'.

Please be aware that you should only attack applications that you have been specifically given permission to test.

URL to attack:

Use traditional spider: ☒

Use ajax spider: with

Progress: Attack complete - see the Alerts tab for details of ar

The bottom toolbar includes icons for History, Search, Alerts, Output, Spider, Insights, AJAX Spider, Active Scan, and a plus icon. The bottom status bar shows "Full".

Below the main panel, a list of alerts is displayed:

- > Application Error Disclosure (7)
- > CSP: Failure to Define Directive with No Fallback (Systemic)
- > CSP: style-src unsafe-inline
- > Content Security Policy (CSP) Header Not Set (4)
- > Sub Resource Integrity Attribute Missing (Systemic)
- > Cookie No HttpOnly Flag (Systemic)
- > Cookie Without Secure Flag (Systemic)

On the right side, a panel titled "Full details" contains the text:

You can ma
history and
You can als